



TechGearAuction – Tài liệu Workflow

Ngày tạo: 24/09/2026 | Phiên bản: Toàn bộ hệ thống Backend + Frontend | Kiến trúc: Clean Architecture
(CQRS + MediatR)



Mục lục

1. WF-01: Đăng ký tài khoản (Register)
2. WF-02: Xác thực Email (Verify Email)
3. WF-03: Đăng nhập (Login) + Anti-Spam Device Check
4. WF-04: Quên mật khẩu & Đặt lại mật khẩu (Forgot / Reset Password)
5. WF-05: Vòng đời Phiên đấu giá (Auction Lifecycle)
6. WF-06: Đặt giá thầu (Place Bid) + Anti-Shill Detection
7. WF-07: Mua ngay (Buy Now)
8. WF-08: Quản lý Profile & Credit
9. WF-09: Tương tác xã hội (Follow / Block / Watch)
10. WF-10: Chat Realtime (Buyer ↔ Seller)
11. WF-11: Báo cáo vi phạm (Report) & Xử lý (Resolve)
12. WF-12: Kháng cáo Banned (Appeal)
13. WF-13: Quản trị Admin (Users / Auctions / Categories / Metrics)
14. WF-14: Background Services (Tự động)
15. WF-15: Thông báo & Realtime (Notifications + SignalR)

WF-01: Đăng ký tài khoản (Register)

📁 `AuthController.cs` → `AuthService.RegisterAsync()`

API Endpoint

Method	Route	Auth	Request Body
POST	/api/auth/register	Anonymous	RegisterDto { Email, DisplayName, Password }

Các bước xử lý (Steps)

1. Kiểm tra email đã tồn tại → Nếu trùng: `throw Exception("Email already exists")`
2. Kiểm tra Email ≤ 256 ký tự.
3. Hash password bằng **BCrypt**.
4. Tạo `User` entity với:
 - `Role = User`, `Status = Active`
 - `AvailableCredits = 3` (Signup Bonus)
 - `IsEmailVerified = false`
 - `EmailVerificationToken` = GUID mới, hạn 24h
5. Tạo `CreditTransaction` ghi nhận +3 credits "Signup Bonus".
6. `SaveChangesAsync()`
7. Gửi email xác thực qua `IService` chứa link verify.

Điểm cần kiểm tra (Checklist)

- ☐ Password validation (min length, complexity) chưa được kiểm tra ở backend.
- ☐ DisplayName validation (max length, XSS) chưa có.
- ☐ Link verify email hard-code `http://localhost:8888` → Cần dùng config.
- ☐ Nếu `SendEmailAsync` fail, user vẫn được tạo nhưng không nhận email → nên wrap trong transaction hoặc retry.
- ☐ Không có rate-limiting cho endpoint register.

WF-02: Xác thực Email (Verify Email)

📁 `AuthController.cs` → `AuthService.VerifyEmailAsync()`

API Endpoint

Method	Route	Auth	Query Params
POST	/api/auth/verify-email	Anonymous	email, token

Các bước xử lý

1. Tìm User theo `email`. Không tìm thấy → return `false`.
2. Nếu đã verify → return `true` (idempotent).
3. So sánh token + kiểm tra expiry (24h).
4. Set `IsEmailVerified = true`, xóa token.
5. `SaveChangesAsync()`

Điểm cần kiểm tra

- ❑ Endpoint dùng `POST` nhưng verify email thường là `GET` link (email client click).
- ❑ Token không được hash → nếu DB bị leak, attacker có thể verify bất kỳ email nào.
- ❑ Không có tính năng "Resend verification email".

WF-03: Đăng nhập (Login) + Anti-Spam Device Check

📁 `AuthController.cs` → `AuthService.LoginAsync()`

API Endpoint

Method	Route	Auth	Headers
POST	/api/auth/login	Anonymous	X-Forwarded-For , X-Device-Hash

Các bước xử lý

1. Tìm User theo email.
2. **Kiểm tra Banned status:**
 - Nếu `user.Status == Banned` → throw `BannedUserException` (kèm `reason`, `violationCount`).
3. **Kiểm tra Device Blacklist:**
 - Tra `BannedDevices` theo `X-Device-Hash` → Nếu device bị ban → throw `BannedUserException`.
4. Xác thực password qua `BCrypt.Verify`.
5. Kiểm tra `IsEmailVerified == true`.
6. Kiểm tra `user.Status == Active`.
7. Lưu `LastLoginIp` và `LastLoginDeviceHash`.
8. Tạo `UserDeviceLog` (IP, DeviceHash).
9. Generate JWT token qua `IJwtProvider`.
10. Trả về `AuthResponseDto { UserId, Email, DisplayName, Role, Token }`.

Điểm cần kiểm tra

- ☐ Thứ tự check: Banned user check trước credential check → tiết lộ email có tồn tại hay không (thông tin bị lộ).
- ☐ Không có cơ chế lock account sau N lần login thất bại.
- ☐ JWT không có refresh token → user phải login lại khi token hết hạn.
- ☐ Không có logout / token revocation.

WF-04: Quên mật khẩu & Đặt lại mật khẩu

AuthController.cs → AuthService.ForgotPasswordAsync() / ResetPasswordAsync()

API Endpoints

Method	Route	Auth	Body / Query
POST	/api/auth/forgot-password	Anonymous	ForgotPasswordDto { Email }
POST	/api/auth/reset-password	Anonymous	ResetPasswordDto { Token, NewPassword }

Các bước xử lý – Forgot Password

1. Tìm user theo email. Nếu không tìm thấy → **silent return** (không quảng lỗi – tránh dò email).
2. Tạo PasswordResetToken (GUID), expiry = 15 phút.
3. SaveChangesAsync()
4. Gửi email chứa token/link reset.

Các bước xử lý – Reset Password

1. Tìm user theo PasswordResetToken .
2. Kiểm tra expiry.
3. Hash mật khẩu mới bằng BCrypt.
4. Xóa token reset.
5. SaveChangesAsync()

Điểm cần kiểm tra

- ☐ Reset link hard-code `http://localhost:8888` .
- ☐ Password reset token không hash → DB leak sẽ bị compromise.
- ☐ Không có rate-limiting cho forgot-password (abuse gửi nhiều email).
- ☐ NewPassword validation chưa có ở backend.

WF-05: Vòng đời Phiên đấu giá (Auction Lifecycle)

 AuctionsController.cs → Commands: Create, UpdateDraft, UploadImage, Publish, Cancel

Trạng thái Auction

Draft

Scheduled

Active

Completed

Cancelled

State Machine

Draft → (Publish) → Scheduled hoặc Active → (EndTime hoặc BuyNow) → Completed

Draft / Scheduled → (Cancel) → Cancelled

Active / Scheduled / Draft → (Admin Force Cancel) → Cancelled

API Endpoints

Method	Route	Auth	Mô tả
POST	/api/auctions	Authorized	Tạo auction mới (Draft)
PUT	/api/auctions/{id}	Authorized	Cập nhật Draft
POST	/api/auctions/{id}/images	Authorized	Upload hình ảnh (max 10, max 5MB, JPG/PNG/WebP)
PUT	/api/auctions/{id}/publish	Authorized	Publish: Draft → Scheduled/Active, trừ 1 credit
PUT	/api/auctions/{id}/cancel	Authorized	Hủy: Draft/Scheduled → Cancelled (hoàn credit nếu Scheduled)
GET	/api/auctions	Anonymous	Danh sách auction (search, filter, paging)
GET	/api/auctions/{id}	Anonymous	Chi tiết auction
GET	/api/auctions/trending	Anonymous	Auction trending
GET	/api/auctions/ending-soon	Anonymous	Auction sắp kết thúc
GET	/api/auctions/recent-winners	Anonymous	Người thắng gần đây
GET	/api/auctions/feed	Authorized	Feed từ người đang follow
GET	/api/auctions/me	Authorized	Auction của tôi

Bước 1: Tạo Auction (CreateAuctionCommand)

1. Validate: $StartPrice \geq 0$, $BidIncrement > 0$, $BuyNowPrice \geq StartPrice$, $EndTime > StartTime$, $Title \leq 200$ chars, $Duration \geq 3h$.
2. Kiểm tra Category tồn tại.
3. Tạo Auction với Status = Draft , CurrentPrice = StartPrice.
4. Convert StartTime/EndTime sang UTC.
5. SaveChangesAsync()

Bước 2: Upload hình ảnh (UploadAuctionImageCommand)

1. Kiểm tra auction tồn tại + thuộc về seller hiện tại.
2. Chỉ upload được khi Status = `Draft` hoặc `Scheduled`.
3. Max 10 ảnh / auction.
4. Upload lên MinIO bucket "auctions" qua `IStorageService`.
5. Ảnh đầu tiên tự động set `IsPrimary = true`.

Bước 3: Publish (PublishAuctionCommand)

1. Kiểm tra chủ auction + Status = `Draft`.
2. Phải có ≥ 1 ảnh.
3. Seller phải có ≥ 1 credit.
4. Trừ 1 credit + tạo `CreditTransaction` (-1).
5. Tăng `TotalAuctionsCreated` trên User.
6. Nếu `StartTime` $\leq$ now $\rightarrow$ Status = `Active` ; ngược lại $\rightarrow$ `Scheduled`.

Bước 4: Cancel (CancelAuctionCommand)

1. Kiểm tra chủ auction.
2. **Active auctions KHÔNG thể cancel** (có thể đang có bidders).
3. Chỉ `Draft` / `Scheduled` mới cancel được.
4. Nếu `Scheduled` $\rightarrow$ **hoàn 1 credit** + tạo `CreditTransaction` (+1 "Refund").

Điểm cần kiểm tra

- ☐ Không có logic chuyển `Scheduled` $\rightarrow$ `Active` khi `StartTime` tới (chỉ background service xử lý `EndTime`, không xử lý `StartTime`).
- ☐ Không thể delete ảnh đã upload.
- ☐ Publish validation chỉ kiểm tra Status = `Draft`, không kiểm tra `Scheduled` (nếu muốn re-publish).
- ☐ File upload ở controller validate extension nhưng command không re-validate $\rightarrow$ inconsistency nếu gọi command trực tiếp.

WF-06: Đặt giá thầu (Place Bid) + Anti-Shill Detection

 AuctionsController.cs → PlaceBidCommand

API Endpoint

Method	Route	Auth	Headers
POST	/api/auctions/{id}/bids	Authorized	X-Forwarded-For , X-Device-Hash

Các bước xử lý

1. Kiểm tra Auction tồn tại + Status = Active + EndTime chưa qua.
2. Seller không được bid trên auction của mình.
3. **Block Check:** Kiểm tra UserBlocks giữa bidder ↔ seller (cả 2 chiều).
4. Tính $\text{minimumBid} = \text{CurrentPrice} + \text{BidIncrement}$. BidAmount phải $\geq \text{minimumBid}$.
5. BidAmount không được $\geq \text{BuyNowPrice}$ (nếu có) → hướng dẫn dùng Buy Now.
6. Tạo Bid entity (kèm IpAddress, DeviceHash).
7. **Anti-Shill Detection (Module 5):**
 - **Check 1:** So sánh IP/DeviceHash của bidder với LastLoginIp / LastLoginDeviceHash của seller → Nếu match: tạo SuspiciousActivity, tăng SuspiciousSellerCount & SuspiciousBidderCount.
 - **Check 2:** So sánh với IP/DeviceHash của các bidder khác trên cùng auction → Nếu match: tạo SuspiciousActivity.
8. Cập nhật auction.CurrentPrice = BidAmount.
9. SaveChangesAsync() với **Optimistic Concurrency Control** (RowVersion) → Nếu conflict: throw ConcurrencyException.
10. Gửi SignalR notification: NotifyNewBidAsync + NotifyPriceUpdateAsync.

Điểm cần kiểm tra

- ☐ Anti-shill chỉ GHI LOG, không CHẶN bid → attacker vẫn thao túng được giá cho đến khi admin review.
- ☐ Không có giới hạn số lần bid liên tục (spam bid).
- ☐ Không kiểm tra bidder có bị Banned hay không trước khi cho bid.
- ☐ BuyNowPrice check dùng $\geq$ → bid bằng đúng BuyNowPrice - BidIncrement vẫn hợp lệ nhưng không trigger buy now.

WF-07: Mua ngay (Buy Now)

 AuctionsController.cs → BuyNowCommand

API Endpoint

Method	Route	Auth
POST	/api/auctions/{id}/buy-now	Authorized

Các bước xử lý

1. Validate: Auction tồn tại, Active, chưa hết hạn, có BuyNowPrice.
2. Seller không được mua auction của mình.
3. Block Check giữa buyer ↔ seller.
4. Tạo Bid với giá = BuyNowPrice.
5. Set `auction.Status = Completed` , `auction.WinnerId = bidderId` .
6. **Tạo ChatRoom** (Active, expires 30 ngày) + SystemMessage "Phòng chat tự động khởi tạo".
7. `SaveChangesAsync()` với OCC.
8. Gửi `NotifyAuctionEndedAsync` qua SignalR.

Điểm cần kiểm tra

- ☐ Không chạy Anti-Shill detection cho Buy Now (khác với Place Bid).
- ☐ Không kiểm tra buyer có bị Banned không.
- ☐ Các bid trước đó của người khác bị mất quyền lợi mà không được notify riêng.

WF-08: Quản lý Profile & Credit

📁 *UsersController.cs* → *UpdateMyProfile, ChangePassword, UpdateAvatar, DepositCredit*

API Endpoints

Method	Route	Mô tả
GET	/api/users/me	Lấy profile cá nhân
PUT	/api/users/me	Cập nhật DisplayName, PhoneNumber, SocialLinks
PUT	/api/users/me/change-password	Đổi mật khẩu
POST	/api/users/me/avatar	Upload avatar (max 5MB, JPEG/PNG/WebP)
POST	/api/users/me/credits/deposit	Nạp credit
GET	/api/users/me/credits/history	Xem lịch sử credit
GET	/api/users/{id}/public-profile	Xem public profile (Anonymous)
GET	/api/metrics/seller/overview	Dashboard seller

Deposit Credit Flow

1. Validate: Amount > 0.
2. Tìm user hiện tại.
3. Cộng credit: `user.AvailableCredits += amount` .
4. Tạo CreditTransaction (+amount, "Nạp Credit hệ thống").

Điểm cần kiểm tra

- ❑ **Deposit Credit không có payment gateway** → user nạp bao nhiêu credit cũng được, không kiểm tra thanh toán thực tế.
- ❑ Update Profile: replace toàn bộ SocialLinks (xóa hết rồi thêm mới) → nếu request thiếu link cũ sẽ bị mất.
- ❑ ChangePassword command: không thấy check Old Password trong code đọc được.

WF-09: Tương tác xã hội (Follow / Block / Watch)

 *UsersController.cs* → *ToggleFollow, ToggleBlock* | *AuctionsController.cs* → *ToggleWatch*

API Endpoints

Method	Route	Mô tả
POST	/api/users/{id}/follow	Toggle follow/unfollow
POST	/api/users/{id}/block	Toggle block/unblock
POST	/api/auctions/{id}/watch	Toggle watch/unwatch auction
GET	/api/users/me/following	Danh sách đang follow
GET	/api/users/me/blocked	Danh sách đã block
GET	/api/users/me/watchlist	Watchlist
GET	/api/users/me/watchlists/ending-soon	Watchlist sắp hết hạn
GET	/api/users/me/bids/active	Bid đang active
GET	/api/users/me/auctions/won	Auction đã thắng

Block User – Workflow đặc biệt

1. Không được tự block mình.
2. Tạo `UserBlock` record.
3. **Tự động xóa Follow 2 chiều** giữa blocker ↔ blocked.
4. **Rollback giá Auction:** Duyệt tất cả Active auctions của blocker → Nếu blocked user đang là Top Bidder:
 - Cancel TẤT CẢ bids của blocked user trên auction đó (`IsCanceled = true`).
 - Tính lại `CurrentPrice` = highest valid bid còn lại, hoặc `StartPrice` nếu không còn bid.
 - Gửi `NotifyPriceUpdateAsync` qua SignalR.

Điểm cần kiểm tra

- ☐ Block chỉ rollback auctions của BLOCKER, không rollback auctions của BLOCKED → nếu blocker đang bid trên auction của blocked, bid đó vẫn tồn tại.
- ☐ Watch: Seller không được watch auction của mình (đã validate), nhưng không kiểm tra user bị block bởi seller.
- ☐ Unblock không khôi phục lại bids đã cancel → mất vĩnh viễn.

WF-10: Chat Realtime (Buyer ↔ Seller)

📁 ChatController.cs → SendMessage, MarkAsRead, Archive, UploadMedia | ChatHub.cs

API Endpoints

Method	Route	Mô tả
GET	/api/chat	Danh sách phòng chat (filter: role, folder)
GET	/api/chat/{roomId}/messages	Tin nhắn (paging)
POST	/api/chat/{roomId}/messages	Gửi tin nhắn
PUT	/api/chat/{roomId}/messages/read	Đánh dấu đã đọc
PUT	/api/chat/{roomId}/archive	Archive phòng chat
POST	/api/chat/{roomId}/media	Upload media (image/video)

ChatRoom tạo tự động khi

- Auction kết thúc có winner (Background Service).
- Buy Now thành công (BuyNowCommand).

Send Message Flow

1. Kiểm tra ChatRoom tồn tại + không Archived.
2. Chỉ seller hoặc winner mới được gửi tin.
3. **Block Check:** Nếu 1 trong 2 bên block → không gửi được.
4. Parse MessageType (Text, Image, Video, SystemText).
5. **Auto-unarchive:** Nếu seller gửi → bỏ archive phía winner; ngược lại.
6. Lưu ChatMessage , IsRead = false.
7. Gửi realtime qua IChatNotificationService.NotifyNewMessageAsync (SignalR).

Điểm cần kiểm tra

- ☐ Upload media không có file size limit ở command (chỉ có ở controller cho auction images, không có cho chat media).
- ☐ Không có rate-limiting cho send message (spam).

- ☐ MarkAsRead gửi SignalR notification cho TỪNG message → nhiều message = nhiều call SignalR → nên batch.
- ☐ ChatRoom chỉ dành cho 1:1 (seller ↔ winner), không hỗ trợ group.

WF-11: Báo cáo vi phạm (Report) & Xử lý

 *ReportsController.cs / AdminReportsController.cs → CreateReport, ResolveReport*

Report Types

- Flake
- Scam
- Harassment

Report Status Flow

- Pending
- Resolved / Rejected

API Endpoints

Method	Route	Auth	Mô tả
POST	/api/reports	User	Tạo report
GET	/api/reports/my-reports	User	Report của tôi
GET	/api/admin/reports	Admin	Tất cả reports
GET	/api/admin/reports/{id}	Admin	Chi tiết report
PUT	/api/admin/reports/{id}/resolve	Admin	Xử lý report
GET	/api/admin/reports/{id}/chat-history	Admin	Xem chat history liên quan

Create Report Flow

1. Không được tự report mình.

2. Kiểm tra reported user, auction (nếu có), chat room (nếu có) đều tồn tại.

3. Tạo Report với Status = Pending.

Resolve Report Flow (Admin)

1. Admin chọn 1 trong 3 hành động:

- **Reject:** Status → Rejected. Không ảnh hưởng user.
- **IssueStrike:** Status → Resolved. `ViolationCount++`. Nếu ≥ 5 → **AUTO-BAN** + blacklist device.
- **DirectBan:** Status → Resolved. Ban user ngay + blacklist device.

2. Tạo `AdminAuditLog`.

 **Cảnh báo:** Khi Auto-ban (5 strikes), ban logic thực hiện trong method riêng nhưng **không tạo AdminAuditLog riêng cho hành động ban** → khó truy vết.

Điểm cần kiểm tra

- ☐ Không có trạng thái "Investigating" trong flow (enum có nhưng không dùng).
- ☐ User có thể report cùng 1 người nhiều lần → spam report.
- ☐ Không notify user bị report hoặc user report khi có kết quả.
- ☐ ReportStatus enum có `Dismissed` nhưng chưa có flow sử dụng.

WF-12: Kháng cáo Banned (Appeal)

📁 AppealsController.cs → SubmitBanAppeal, ResolveAppeal

API Endpoints

Method	Route	Auth	Mô tả
POST	/api/appeals/banned-users	Anonymous (banned user gửi)	Gửi kháng cáo kèm bằng chứng
GET	/api/appeals	Admin	Danh sách appeals
PUT	/api/appeals/{id}/resolve	Admin	Duyệt / Từ chối appeal

Submit Ban Appeal Flow

1. Tìm user bằng email (Anonymous endpoint – user đã bị ban không login được).
2. Kiểm tra `user.Status == Banned` (nếu không bị ban → throw).
3. Upload evidence files lên MinIO (images → bucket "images", khác → "chat-media").
4. Tạo `Appeal` với `Status = Pending` + các `AppealEvidence`.

Resolve Appeal Flow (Admin)

1. Nếu **Approve**:
 - `User.Status` → Active.
 - Xóa device khỏi `BannedDevices`.
 - Nếu `ViolationCount` ≥ 5 → giảm xuống 4 (tránh auto-ban lại ngay).
2. Nếu **Reject**: `Appeal.Status` → Rejected. User vẫn bị ban.
3. Tạo `AdminAuditLog`.

Điểm cần kiểm tra

- ☐ Banned user có thể gửi nhiều appeal cùng lúc (không giới hạn).
- ☐ Evidence bucket routing: video file sẽ vào "chat-media" thay vì bucket riêng → lẫn với media chat.
- ☐ Approve chỉ giảm `ViolationCount` xuống 4 → nếu nhận thêm 1 strike sẽ bị ban lại ngay.
- ☐ Không notify user khi appeal được resolve.

WF-13: Quản trị Admin

 *AdminUsersController, AdminAuctionsController, AdminCategoriesController, AdminMetricsController, AdminBlacklistsController, AdminAuditLogsController, AdminSuspiciousActivitiesController*

Admin User Management

Method	Route	Mô tả
GET	/api/admin/users	Danh sách users (search, filter, paging)
GET	/api/admin/users/{id}	Chi tiết user
PUT	/api/admin/users/{id}	Cập nhật profile user
PUT	/api/admin/users/{id}/close	Đóng tài khoản (Closed + DeletedAt)
PUT	/api/admin/users/{id}/restore	Khôi phục tài khoản
PUT	/api/admin/users/{id}/ban	Ban user + blacklist device
PUT	/api/admin/users/{id}/unban	Unban user

Admin Auction Management

Method	Route	Mô tả
GET	/api/admin/auctions	Tất cả auctions
PUT	/api/admin/auctions/{id}/force-cancel	Hủy cưỡng chế bất kỳ auction nào (trừ Completed/Cancelled)

Force Cancel Flow

1. Kiểm tra auction không phải Completed/Cancelled.
2. Nếu Scheduled hoặc Active → hoàn 1 credit cho seller.
3. Set Status = Cancelled.
4. Tạo AdminAuditLog.
5. Gửi SignalR notification "No Winner (Cancelled by Admin)".

Admin Category Management

Method	Route	Mô tả
POST	/api/admin/categories	Tạo category
PUT	/api/admin/categories/{id}	Cập nhật category
DELETE	/api/admin/categories/{id}	Xóa category

Admin Monitoring

Method	Route	Mô tả
GET	/api/admin/metrics/overview	Tổng quan hệ thống
GET	/api/admin/metrics/revenue-chart	Biểu đồ doanh thu
GET	/api/admin/blacklists	Danh sách device bị blacklist
DELETE	/api/admin/blacklists/{hash}	Xóa device khỏi blacklist
GET	/api/admin/audit-logs	Nhật ký thao tác admin
GET	/api/admin/suspicious-activities	Hoạt động nghi vấn
PUT	/api/admin/suspicious-activities/{id}/review	Đánh dấu đã review

Điểm cần kiểm tra

- ☐ Ban user: Blacklist device nhưng **Unban user KHÔNG xóa device khỏi blacklist** → device vẫn bị chặn dù user được unban.
- ☐ Close account: Set DeletedAt nhưng không có soft-delete logic ở query (user vẫn hiện trong danh sách).
- ☐ Delete category: Không kiểm tra xem có auction nào đang dùng category đó → FK violation tiềm ẩn.
- ☐ Force Cancel: Không cancel các bids đang chạy → bidders không nhận thông báo phù hợp.
- ☐ Admin update profile: Tạo AuditLog nhưng admin update profile user thường KHÔNG nên có → tách rõ admin vs. user action.
- ☐ ReviewSuspiciousActivity chỉ set `IsReviewed = true` → không có action follow-up.

WF-14: Background Services (Tự động)

 Infrastructure/Services/AuctionClosingBackgroundService.cs, ChatRoomArchivingBackgroundService.cs

Service 1: AuctionClosingBackgroundService

Tần suất	Chức năng
Mỗi 10 giây	Đóng auction hết hạn

1. Query tất cả Auctions: Status = Active AND EndTime $\leq$ now.
2. Với mỗi auction:
 - **Có bid:** WinnerId = highest bidder, Status = Completed. Tạo ChatRoom (30 ngày) + SystemMessage. Gửi SignalR notification.
 - **Không có bid:** Status = Completed (dù không có winner).
3. Batch SaveChangesAsync() cho tất cả auctions.

 **Lỗi tiềm ẩn:** Auction không có bid vẫn set Status = Completed thay vì Cancelled hoặc trạng thái riêng "Unsold" → gây nhầm lẫn khi query. Comment trong code ghi "Or Cancelled/Unsold" nhưng code thực tế set Completed.

Service 2: ChatRoomArchivingBackgroundService

Tần suất	Chức năng
Mỗi 1 giờ	Archive chat room hết hạn

1. Query ChatRooms: Status = Active AND ExpiresAt $\leq$ now.
2. Set Status = Archived cho tất cả.

Điểm cần kiểm tra

- ☐ **Không có service chuyển Scheduled → Active** khi StartTime tới → auction Scheduled vĩnh viễn không chuyển Active nếu Publish trước StartTime.
- ☐ Auction closing query không lọc bids có IsCanceled = true → winner có thể là bidder đã bị cancel.
- ☐ Background service batch save: Nếu 1 auction lỗi, toàn bộ batch rollback.

- ☐ Polling 10s cho auction closing có thể gây tải DB nếu có nhiều auction.

WF-15: Thông báo & Realtime (Notifications + SignalR)

 *NotificationsController.cs, AuctionHub.cs, ChatHub.cs*

API Endpoints

Method	Route	Mô tả
	<code>/api/notifications/unread</code>	Lấy thông báo chưa đọc
	<code>/api/notifications/{id}/read</code>	Đánh dấu đã đọc

SignalR Hubs

Hub	Events phát ra
<code>/hubs/auction</code>	NewBid, PriceUpdate, AuctionEnded
<code>/hubs/chat</code>	NewMessage, MessageRead

Khi nào hệ thống gửi realtime?

- **PlaceBid:** NotifyNewBidAsync + NotifyPriceUpdateAsync → AuctionHub
- **BuyNow:** NotifyAuctionEndedAsync → AuctionHub
- **AuctionClosingService:** NotifyAuctionEndedAsync → AuctionHub
- **BlockUser (cancel bid):** NotifyPriceUpdateAsync → AuctionHub
- **ForceCancelAuction:** NotifyAuctionEndedAsync → AuctionHub
- **SendMessage:** NotifyNewMessageAsync → ChatHub
- **MarkAsRead:** NotifyMessageReadAsync → ChatHub

Điểm cần kiểm tra

- ☐ Notification entity (persisted) chỉ có endpoint đọc → không có logic tạo notification trong code command → chỉ dùng SignalR (volatile), không persist.
- ☐ Nếu user offline, notification SignalR bị mất → cần message queue hoặc persistent notification.
- ☐ AuctionHub và ChatHub rất mỏng (< 10 dòng) → logic realtime nằm trong service, hub chỉ expose.



Tổng hợp: Bản đồ API Endpoints

#	Module	GET	POST	PUT	DELETE	Tổng
1	Auth	0	4	0	0	4
2	Auctions	8	4	3	0	15
3	Users / Profile	8	3	2	0	13
4	Chat	2	2	2	0	6
5	Reports	1	1	0	0	2
6	Notifications	1	0	1	0	2
7	Categories (Public)	2	0	0	0	2
8	Metrics (Seller)	1	0	0	0	1
9	Admin Users	2	0	5	0	7
10	Admin Auctions	1	0	1	0	2
11	Admin Reports	3	0	1	0	4
12	Admin Categories	0	1	1	1	3
13	Admin Metrics	2	0	0	0	2
14	Admin Blacklists	1	0	0	1	2
15	Admin Audit Logs	1	0	0	0	1
16	Admin Suspicious	1	0	1	0	2
17	Appeals	1	1	1	0	3
	TỔNG	35	16	18	2	71



Domain Entities Tổng hợp (22 entities)

Entity	Mô tả
User	Tài khoản (email, credits, role, status, violation tracking)
Auction	Phiên đấu giá (lifecycle, pricing, OCC via RowVersion)
AuctionImage	Ảnh đính kèm auction (max 10, stored MinIO)
AuctionWatch	Watchlist mapping (User ↔ Auction)
Bid	Giá thầu (amount, IP, DeviceHash, IsCanceled)
Category	Danh mục sản phẩm (hierarchy support)
ChatRoom	Phòng chat seller-winner (auto-create, 30d expiry)
ChatMessage	Tin nhắn (Text/Image/Video/System, read tracking)
CreditTransaction	Lịch sử giao dịch credit (+/-)
Notification	Thông báo persisted (chưa tích hợp đầy đủ)
Report	Báo cáo vi phạm (Flake/Scam/Harassment)
ReportEvidence	Bằng chứng đính kèm report
Appeal	Kháng cáo ban (Pending/Approved/Rejected)
AppealEvidence	Bằng chứng kháng cáo
SuspiciousActivity	Hoạt động nghi vấn shill bid
BannedDevice	Device hash bị blacklist
UserDeviceLog	Nhật ký đăng nhập device
UserFollow	Follow mapping (Follower ↔ Followee)
UserBlock	Block mapping (Blocker ↔ Blocked)
UserSocialLink	Link mạng xã hội (Platform + URL)
AdminAuditLog	Nhật ký thao tác admin
BaseEntity	Base class (Id, CreatedAt, UpdatedAt, DeletedAt)

Tổng hợp Các Vấn đề Cần Kiểm tra (Priority)

Mức độ	Mô tả	Workflow
CRITICAL	Không có service chuyển Scheduled → Active (auction bị kẹt ở Scheduled)	WF-05, WF-14
CRITICAL	AuctionClosing không lọc bids IsCanceled → winner có thể là bidder đã bị cancel	WF-14
CRITICAL	Auction no-bid set Completed thay vì Unsold/Cancelled	WF-14
CRITICAL	Deposit Credit không có payment verification → unlimited free credits	WF-08
HIGH	Unban user không xóa device khỏi blacklist	WF-13
HIGH	Login check thứ tự: Banned → Credentials → tiết lộ email tồn tại	WF-03
HIGH	Không kiểm tra bidder banned trước khi cho bid	WF-06, WF-07
HIGH	Hard-coded localhost URLs cho email links	WF-01, WF-04
HIGH	Anti-shill chỉ log, không chặn → vẫn thao túng giá được	WF-06
HIGH	Không có JWT refresh token / logout / revocation	WF-03
MEDIUM	Không rate-limiting: register, forgot-password, bid, message	WF-01, WF-04, WF-06, WF-10
MEDIUM	Tokens (email verify, password reset) không hash trong DB	WF-02, WF-04
MEDIUM	Block: không rollback bids của blocker trên auction của blocked	WF-09
MEDIUM	Delete category không check FK → auction mồ côi	WF-13
MEDIUM	Notification entity không tạo ở command → chỉ volatile SignalR	WF-15
LOW	Password/DisplayName validation thiếu ở backend	WF-01
LOW	Chat media upload không limit file size ở command	WF-10
LOW	MarkAsRead gửi N SignalR calls → nên batch	WF-10
LOW	Resend verification email chưa có	WF-02

— Hết tài liệu — Tạo tự động bởi AI Agent — TechGearAuction Workflow Documentation v1.0 —